Lab 01 — Security Controls Categorization

> **SY0-701 Objective 1.1** — Compare and contrast various types of security controls.
>
> **Domain 1** — General Security Concepts (12%) · **Time:** ~35 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: Classify real controls by category and type, then implement a preventive, deterrent, detective, corrective and compensating control on one Linux host and prove each one works.

You'll build: A control matrix (`/root/lab01/controls.csv`), an iptables Telnet block with a jump-host exception and logging, an SSH warning banner, an auditd watch on `/etc/passwd`, a known-good restore of a tampered file, and an evidence file mapping each control you built.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; no earlier lab needed; tools installed in step 1.

Background

- A control **category** describes *how* it is implemented: **technical** (hardware/software), **managerial** (planning and oversight), **operational** (carried out by people) or **physical** (acts on the physical world).
- A control **type** describes *what it achieves*: **preventive** (stops it), **deterrent** (discourages it), **detective** (records or alerts), **corrective** (fixes the damage), **compensating** (substitutes for a control that is not feasible) and **directive** (tells people what to do).
- One control always has both a category and a type, and many controls have more than one type. A visible CCTV camera is physical, detective and deterrent.
- Defence in depth layers several types so that when prevention fails, detection and correction still work.

Steps

1. Install the tools

You need iptables for the preventive control, auditd for the detective control, and `column` (bsdextrautils) to print the matrix neatly.

```
apt-get update -qq && apt-get install -y iptables auditd bsdextrautils curl openssh-server
systemctl enable --now auditd
mkdir -p /root/lab01 /run/sshd && cd /root/lab01
```

2. Build the control matrix

Classify twelve everyday controls by category and type. Read each row and decide on the answer yourself before you look at the right-hand columns.

```
cat > /root/lab01/controls.csv <<'EOF'
Control,Category,Type
```

```
Locked server-room door,Physical,Preventive
Warning sign at the perimeter fence,Physical,Deterrent
CCTV recording the lobby,Physical,Detective
Fire suppression system,Physical,Corrective
Acceptable use policy,Managerial,Directive
Annual risk assessment,Managerial,Preventive
Quarterly user access review,Operational,Detective
Security awareness training,Operational,Preventive
Firewall DROP rule on port 23,Technical,Preventive
IDS alert on a port scan,Technical,Detective
Restore server from backup,Operational,Corrective
Isolated VLAN for an unpatchable host,Technical,Compensating
EOF
column -t -s, /root/lab01/controls.csv
echo "--- controls per type ---"; tail -n +2 /root/lab01/controls.csv | cut -d, -f3 | sort
| uniq -c
```

3. Add a technical preventive control

Start a stand-in "Telnet" service on port 23, prove it answers, then drop inbound TCP/23 with iptables and prove the same request now fails. Loopback traffic passes through the INPUT chain, so the test works on one host.

```
nohup python3 -m http.server 23 --bind 127.0.0.1 >/dev/null 2>&1 &
sleep 1
curl -s -m 3 -o /dev/null -w "before rule: HTTP %{http_code}\n" http://127.0.0.1:23/
iptables -I INPUT -p tcp --dport 23 -j DROP
curl -s -m 3 -o /dev/null -w "after rule: HTTP %{http_code}\n" http://127.0.0.1:23/ ||
echo "after rule: connection timed out (blocked)"
iptables -L INPUT -n --line-numbers | head -5
```

```
before rule: HTTP 200
after rule: HTTP 000
after rule: connection timed out (blocked)
```

4. Add a deterrent and directive control

A login warning banner does not stop anyone, but it discourages casual attackers (deterrent) and tells users the rules (directive). Validate the SSH configuration with `sshd -T` instead of restarting the daemon.

```
cat > /etc/issue.net <<'EOF'
WARNING: Authorised users only. All activity on this system is monitored and logged.
Unauthorised access is an offence under the Computer Misuse Act 1993 (Singapore).
EOF
echo "Banner /etc/issue.net" > /etc/ssh/sshd_config.d/10-banner.conf
sshd -t && sshd -T | grep -i '^banner'
cat /etc/issue.net
```

5. Add a technical detective control

auditd records events but never blocks them. Watch `/etc/passwd` for writes and attribute changes, then trigger a legitimate change by adding a user.

```
auditctl -w /etc/passwd -p wa -k passwd_changes
auditctl -l
useradd -m lab01user
sleep 1
ausearch -k passwd_changes -i | grep -E "type=SYSCALL" | tail -3
```

6. Add a corrective control

Take a known-good copy and hash of the banner, simulate a defacement, detect it with the hash, and correct it by restoring the known-good copy.

```
mkdir -p /root/known-good
cp -a /etc/issue.net /root/known-good/issue.net
sha256sum /etc/issue.net > /root/known-good/issue.net.sha256
echo "Welcome! Everyone is allowed in." > /etc/issue.net
sha256sum -c /root/known-good/issue.net.sha256 || cp -a /root/known-good/issue.net
/etc/issue.net
sha256sum -c /root/known-good/issue.net.sha256
```

```
/etc/issue.net: FAILED
sha256sum: WARNING: 1 computed checksum did NOT match
/etc/issue.net: OK
```

7. Add a compensating control

Assume a legacy device must keep Telnet and cannot be patched. Compensate by allowing port 23 only from a jump host (10.10.10.5) and logging every attempt. Rule order matters: LOG first, then ACCEPT from the jump host, then the DROP from step 3.

```
iptables -I INPUT 1 -s 10.10.10.5 -p tcp --dport 23 -j ACCEPT
iptables -I INPUT 1 -p tcp --dport 23 -j LOG --log-prefix "LEGACY-TELNET " --log-level 4
iptables -L INPUT -n --line-numbers | head -6
curl -s -m 3 -o /dev/null http://127.0.0.1:23/ || echo "non-jump-host access still
blocked"
dmesg | grep LEGACY-TELNET | tail -2
```

8. Map what you built back to the matrix

Record each control you implemented with its category, type and evidence. This is the artefact an auditor or reviewer would ask for.

```
cat > /root/lab01/evidence.csv <<'EOF'
Implemented control,Category,Type,Evidence
iptables DROP tcp/23,Technical,Preventive,iptables -L INPUT
SSH warning banner,Technical,Deterrent + Directive,sshd -T | grep banner
auditd watch on /etc/passwd,Technical,Detective,ausearch -k passwd_changes
Known-good restore of /etc/issue.net,Operational,Corrective,sha256sum -c
Jump-host-only Telnet + LOG,Technical,Compensating,iptables -L INPUT and dmesg
EOF
column -t -s, /root/lab01/evidence.csv
```

Test it

Confirm all five controls are live.

```
iptables -S INPUT | grep -- "--dport 23"
sshd -T | grep -i '^banner'
ausearch -k passwd_changes -i | grep -c lab01user
sha256sum -c /root/known-good/issue.net.sha256
```

Expected: three iptables rules for port 23 (LOG, ACCEPT from 10.10.10.5, DROP), `banner /etc/issue.net`, a count of 1 or more audit records mentioning `lab01user`, and `/etc/issue.net: OK`.

Troubleshooting

Symptom	Fix
`auditctl` says the audit system is disabled or `ausearch` returns `<no matches>`	Run `systemctl restart auditd`, re-add the rule with `auditctl -w /etc/passwd -p wa -k passwd_changes`, then repeat the `useradd`.
`sshd -t` reports `Missing privilege separation directory: /run/sshd`	Run `mkdir -p /run/sshd` and repeat the check.
No `LEGACY-TELNET` lines appear in `dmesg`	Kernel logging may be rate-limited or routed to the journal; check `journalctl -k | grep LEGACY-TELNET`. The rule order in `iptables -L INPUT --line-numbers` must show LOG above DROP.

Challenge

Add a **physical-world equivalent** for each technical control you built (for example, a locked comms cabinet for the iptables rule) and a second **detective** control: an auditd watch on `/etc/ssh/sshd_config.d/` with the key `ssh_config_changes`. Prove it fires by editing the banner file again.

Reflection

A company cannot patch a legacy system, so it isolates it and logs every connection. Which control type is that, and why is it not "corrective"?

Exam tips

- Category is *how* (technical, managerial, operational, physical); type is *what it does* (preventive, deterrent, detective, corrective, compensating, directive).
- A sign or banner is a **deterrent**; a lock or firewall rule is **preventive**. A policy is **directive**.
- **Compensating** substitutes for a control you cannot implement; **corrective** repairs the damage after an incident.
- Detective controls (logs, IDS, CCTV, audits) record or alert but never stop an attack on their own.

References

- NIST SP 800-53 Rev. 5 control catalogue — https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
- CIS Critical Security Controls v8 — https://www.cisecurity.org/controls

- Linux audit framework (`auditctl`, `ausearch` man pages) — https://man7.org/linux/man-pages/man8/auditctl.8.html
- iptables man page — https://manpages.ubuntu.com/manpages/jammy/man8/iptables.8.html

---